

Procedure

PROC-IR — Incident Response and NIS2 Reporting Procedure

Version 1.3.0 · approved · classification internal

Document id	PROC-IR
Type	Procedure
Status	approved
Version	1.3.0
Classification	internal
Owner	Information Security Officer / ISMS Manager (Alex Rossi)
Approver	Managing Director (Dana Weber)
Effective date	2026-04-13
Last reviewed	2026-04-13
Review cycle	1 year
Next review	2027-04-13
Applies to	all entities in scope
Annex A controls	A.5.5, A.5.24, A.5.25, A.5.26, A.5.28, A.6.8
ISO/IEC 27001 clauses	7.4
Related documents	POL-IR, POL-LOG, POL-BC, POL-LEG, POL-ORG

Digital signature. When this PDF is produced by the release pipeline it carries a PAdES signature of the ISMS document-control key, shown at the bottom of this page; verify it with `isms verify` or any PDF reader. An unsigned copy is not a controlled document.

Digital signature (PAdES) — applied by the release pipeline. An unsigned copy is not a controlled document.

Digitally signed by
ISMS Document Control - UNTRUSTED DEVELOPMENT KEY
2026-08-20 22:09:20 CEST
UNTRUSTED DEVELOPMENT KEY - not a controlled copy

Purpose

This is the step-by-step procedure behind POL-IR: how events are reported and triaged, how incidents are declared, contained, eradicated and recovered, how evidence is preserved, how and when authorities, data subjects, carriers and the insurer are informed, how communication runs, and how every incident is closed with its lessons. The NIS2 reporting clock is the backbone of stage 6.

Scope

All information security events and incidents affecting any in-scope entity, system, site or service, around the clock, and everyone who detects, reports or handles them.

Procedure

1. Detection and reporting

1. Anyone who notices a suspected event reports it within one hour (POL-IR IR-6) through the security mailbox, the 24/7 hotline (for anything that looks like S1 or S2), the incident form in the ticket system or — for technicians — the report function of the maintenance tablet. Automated alerts from the central log store, the fleet-management plane, endpoint protection and the mail gateway open tickets in project INC directly (POL-LOG LOG-7).
2. A report states what was observed, where (system, locker id, site), when, by whom and what has already been done. Reporters do not investigate, shut down or wipe anything unless the on-call responder instructs them.

2. Triage and assessment (A.5.25)

1. The on-call responder acknowledges the report — within 30 minutes for a suspected S1, one hour for S2, one working day otherwise — gathers the first facts from the log store and the reporter, and decides: event closed, or incident declared with a severity per POL-IR IR-2.
2. For every declared incident the responder runs two tests and records the answers in the ticket: the **NIS2 significance test** (severe operational disruption or financial loss for PaketPort, or considerable damage to others — "yes", "no" or "not yet determinable", with the time PaketPort became aware) and the **personal-data test** (personal data involved — yes, no or unknown), which brings in the Data Protection Officer. The awareness time starts the reporting clock of stage 6.

3. Declaration and mobilisation (A.5.24)

1. For S1 and S2 the responder pages the incident manager — the Information Security Officer / ISMS Manager or deputy — who opens the war-room channel and appoints the response team (the on-call engineer of the Head of Platform & SRE, the Security Engineer, the IT Operations Lead as needed, the entity lead of the affected entity), the

communications lead and, where personal data or legal exposure is involved, the Data Protection Officer and legal counsel. The Managing Director is informed of every S1 within one hour of declaration.

2. S3 and S4 incidents are handled by the responder with the system owner under the playbooks and reviewed by the incident manager at closure.

4. Containment, eradication and recovery (A.5.26)

1. Containment follows the playbook of the scenario: isolate lockers or device groups through the fleet-management plane; block accounts, tokens and certificates; revoke and rotate credentials and keys (POL-CRYP CRYP-14); segment or disconnect affected networks; and preserve evidence first where containment would destroy it (stage 5). Actions that affect the service require the incident manager's approval (POL-IR IR-9).
2. Eradication removes the cause — malware, rogue accounts, vulnerable components — with a verified fix under the emergency change rules of POL-VULN and POL-SDLC.
3. Recovery restores from backups or fails over under POL-BC, re-provisions lockers with a clean signed image, re-enables services in stages under heightened monitoring, and verifies that the indicators of compromise are gone before the incident manager declares the service normal. Security controls stay in force throughout (POL-BC BC-3).

5. Evidence collection (A.5.28)

1. Before changes are made, the Security Engineer secures evidence: exports of the relevant logs from the central store with their hashes, forensic images of affected systems and locker controllers (controllers are pulled by a technician and transported under POL-CLS CLS-9), memory captures where feasible, screenshots and a timeline.
2. Each item is entered in the evidence log with collector, time, method, hash and storage location. Evidence is kept in the incident evidence store (restricted), physical items in the key-handling room, and every handover is recorded (chain of custody). Legal counsel may place a legal hold that suspends deletion under POL-LEG.

6. Regulatory and contractual reporting (A.5.5)

1. The incident manager keeps the reporting log: for each obligation the deadline, the person responsible, the time sent, the recipient and the reference number.

Obligation	Trigger	Deadline	Content	Who reports
NIS2 early warning	Significant incident (stage 2 test "yes")	Within 24 hours of awareness	Whether the incident is suspected to be caused by unlawful or malicious acts, whether it could have cross-border impact, contact details	Information Security Officer / ISMS Manager to the Austrian competent authority and CERT.at; the Country Manager Germany and the Site Lead Brno to the competent authority and CSIRT of their entity as listed in the legal register

Obligation	Trigger	Deadline	Content	Who reports
NIS2 incident notification	After the early warning	Within 72 hours of awareness	Initial assessment, severity and impact, indicators of compromise; updates the early warning	As above
NIS2 intermediate report	Request of the CSIRT or the authority	As requested	Status updates and interim findings	As above
NIS2 final report	After the notification	Within one month of the notification; if the incident is still ongoing, a progress report and then the final report within one month of handling it	Detailed description, type of threat or root cause, applied and ongoing mitigation, cross-border impact	As above
GDPR supervisory authority	Personal-data breach likely to result in a risk	Within 72 hours of awareness	Nature of the breach, categories and numbers, contact, likely consequences, measures	Data Protection Officer, to the authority of the entity's country
GDPR data subjects	High risk to the persons concerned	Without undue delay	Plain-language description, contact, consequences, measures	Data Protection Officer with the communications lead
Carriers	Confirmed impact on a carrier's data or service	Within 24 hours of confirmation (LEG-05)	Impact, measures, expected resolution	Head of Procurement or the supplier owner
Cyber insurer	Incident that may give rise to a claim	Per the policy conditions (LEG-08)	Facts, impact estimate	Managing Director
Cyber Resilience Act	Actively exploited vulnerability in, or severe incident affecting, the locker product	Early warning within 24 hours, notification within 72 hours, final report within the deadline of the Regulation	Vulnerability or incident details, mitigation, corrective measures	Software Engineering Lead with the Information Security Officer / ISMS Manager
Site hosts and customers	Physical damage or impact on collection	As agreed or as needed	Practical information	Communications lead

1. A "not yet determinable" significance is re-assessed every four hours until decided; when in doubt the early warning is sent — a withdrawn warning costs less than a missed deadline.
2. Only the roles named above and in POL-ORG ORG-10 contact authorities, and every contact is logged. Contact data comes from the legal register and is verified semi-annually (POL-ORG ORG-9).

7. Communication (clause 7.4)

1. Internal: the incident manager posts status in the war-room channel at the intervals of POL-IR IR-2 and informs the affected teams; staff-wide notices ("do not open emails with subject X") go through the communications lead.
2. External: customer notices through the app and the website, site-host notices through the field-service dispatch, and press statements are drafted by the communications lead and approved by the Managing Director (POL-IR IR-11); carriers are informed by the supplier owner under stage 6.

8. Closure and lessons learned

1. The incident manager closes the incident when the service is normal, the evidence is secured, the reporting obligations are met and the ticket is complete. The post-incident review takes place within ten working days for S1, S2 and selected S3 incidents, with the timeline, the root cause, what worked and what did not, and actions entered in PROC-CAPA; the risk register is updated under PROC-RISK, and sanitised lessons go into the monthly awareness communication.

9. Exercises

1. Tabletop exercises run at least twice a year under POL-IR IR-4: one rehearses the reporting clock end to end including draft early-warning texts, one includes PaketPort Deutschland GmbH and a field-service scenario. Every exercise produces a record and actions in PROC-CAPA.

Records

Record	Where it is kept	Retention	Owner
Incident tickets (project INC) with timeline and decisions	Ticket system	10 years	Information Security Officer / ISMS Manager
Reporting log with timestamps and references	Ticket system, attached to the incident	10 years	Incident manager
Evidence log and evidence items	Incident evidence store (restricted); key-handling room for physical items	Closure plus 3 years; longer under legal hold	Security Engineer
Post-incident review reports	Ticket system, project INC	10 years	Information Security Officer / ISMS Manager
Exercise records	Ticket system, project ISMS-EXERCISE	3 years	Information Security Officer / ISMS Manager
Communications issued	Communications archive	10 years	Communications lead

Related documents

- POL-IR — Information Security Incident Response Policy

- POL-LOG — Logging and Monitoring Policy
- POL-BC — Business Continuity & Backup Policy
- POL-LEG — Legal, Regulatory and Privacy Compliance Policy
- POL-ORG — Information Security Roles and Governance Policy

Revision history

Version	Approved	Changes
1.3.0	2026-04-13	Reporting paths for the German and Czech authorities and CSIRTs.; Evidence-collection step aligned with the central log store.
1.2.0	2025-11-01	Severity model and reporting clock aligned with POL-IR 1.2.0.
1.1.0	2025-05-05	Tabletop exercise schedule.
1.0.0	2024-05-06	Initial approved version.

Approval and control

Approved by the Managing Director (Dana Weber) on 2026-04-13; owned by the Information Security Officer / ISMS Manager (Alex Rossi). The approval is recorded in version control as the reviewed and merged pull request of this version (PROC-DOC, stage 3).

Source digest sha256:8f96c01d1ee0829b7d819adde4910493a90efc651dff88f8739caa0026f3e31d · rendered by isms-as-code from the repository sources.